

# Guide du Responsable Sécurité de l'Information



## Conception du Système de Résilience et Alignement sur les Normes

Ce système de résilience a été conçu par Risk and Strategic Management, Corp (RSM), une société spécialisée dans la conception et la mise en œuvre de stratégies de résilience complexes qui protègent les personnes, les installations, les actifs, les informations, les opérations et la réputation de l'organisation. Ce système a été aligné sur les normes ISO et BSI suivantes afin de garantir qu'il reflète les normes et pratiques professionnelles des organisations à haute fiabilité : ISO 31000 : Gestion du risque ; ISO 22317 : Analyse de l'impact sur l'entreprise ; ISO 22301 : Gestion de la continuité de l'activité ; ISO 22320 : Gestion des urgences ; ISO 34001 : Sécurité et résilience ; ISO 22316 : Résilience organisationnelle ; et BSI 17091 : Gestion de crise.

# Pourquoi la Sécurité de l'Information est-elle Nécessaire?

Une sécurité efficace de l'information garantit qu'aucune donnée n'est perdue, volée ou laissée sans protection, quel que soit son degré de sensibilité. Toute information susceptible de causer du tort ou de l'embarras aux individus, à l'organisation ou aux parties prenantes externes par des criminels, des gouvernements hostiles, des médias, des militants ou des terroristes doit être considérée comme sensible et doit être protégée de manière appropriée. Voici des exemples spécifiques d'informations sensibles :

- Informations contractuelles et financières
- Plans et rapports opérationnels
- Stratégies organisationnelles
- Informations sur les parties prenantes externes
- Propositions commerciales
- Visites et activités de VIP
- Propriété intellectuelle
- Dossiers et programmes de voyages
- Biodonnées du personnel et dossiers des Proches Parents
- Rapports de promotion et de discipline
- Politiques ou rapports sur les crises et les incidents
- Documents d'assurance
- Dossiers de rémunération
- Réunions et événements avec les clients
- Enquêtes
- Politiques et plans de sécurité

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

Les risques liés à une mauvaise sécurité de l'information sont les suivants :

- Vols, vols qualifiés, agressions et cambriolages
- Agressions entraînant des blessures ou la mort
- Enlèvements et prises d'otages
- Attaques à main armée
- Couverture médiatique négative
- Perte d'avantages concurrentiels et d'activités
- Embarras de l'individu ou de l'organisation
- Risques juridiques et de réputation
- Atteinte au moral des employés
- Tort aux parties prenantes externes

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

# Responsabilités de la Direction

Les responsables sont chargés de veiller à ce que les protocoles physiques et procéduraux de sécurité de l'information soient appliqués par l'ensemble du personnel et des sous-traitants afin de prévenir le vol ou la perte de données. L'absence de mise en œuvre de ces mesures peut entraîner une violation de la sécurité. L'efficacité de la sécurité de l'information repose sur :

- La limitation de l'accès aux données en utilisant des couches de cryptage et des protocoles de sécurité
- La mise en œuvre et l'application d'une « politique claire »
- la sécurisation des actifs physiques de stockage des données ou des informations sur papier
- La réduction des vulnérabilités qui pourraient permettre la perte ou le vol de données
- Le signalement immédiat des violations de la sécurité
- La garantie que le personnel est formé et géré de manière appropriée

Insérez ici des informations supplémentaires si nécessaire

Insérez ici des informations supplémentaires si nécessaire

La sécurité de l'information est basée sur :

| La Confidentialité                                                                         | L'Intégrité                                                                                         | La Disponibilité                                                                                            |
|--------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Prévention de la divulgation d'informations à des personnes ou des systèmes non autorisés. | Prévention de la modification des systèmes ou du stockage des données sans autorisation appropriée. | Maintien de la disponibilité des données et des systèmes pour une utilisation par des personnes autorisées. |

## La Confidentialité

Les données qui se trouvent dans des serveurs, des bases de données, des dossiers papier ou qui sont visibles sur les bureaux des membres du personnel ou dans des zones ouvertes ne doivent pas être consultées par des personnes qui n'ont pas l'autorisation, l'identification et/ou la protection appropriées. La confidentialité comprend :

- **L'habilitation** : Il s'agit d'une base de protection fondée sur les niveaux de défense. Il s'agit de la quantité de données à laquelle vous êtes autorisé à accéder et/ou du moment où vous pouvez y accéder. Les personnes ou les systèmes qui bénéficient d'une habilitation « supérieure » sont autorisés à accéder à davantage de données.
- **l'identification** : Il s'agit d'une base permettant de montrer que vous avez l'habilitation correcte. Elle tourne autour de *quelque chose que vous savez, que vous avez ou que vous êtes*. Voici un exemple de chacun de ces éléments : *quelque chose que vous savez* : « Quel est le nom de jeune fille de votre mère ? », un numéro d'identification PIN ou un mot de passe ; *quelque chose que vous avez* : un lecteur magnétique, un permis de conduire ; *quelque chose que vous êtes* : des données biométriques (par exemple, un scan de la rétine, des empreintes digitales, des empreintes vocales, etc.)
- **La protection** : La protection comprend deux parties : l'autorisation et l'identification [1]. L'autorisation est le plus souvent représentée par un nom d'utilisateur ou une carte magnétique et [2] l'identification est un mot de passe ou un mot clé attribué à cette identification.

Il y a « violation » lorsque des personnes non autorisées accèdent à des données. Le responsable doit signaler immédiatement une violation et commencer à chercher l'emplacement de la violation dans le système - c'est-à-dire le *point d'entrée* où la violation s'est produite. Lorsque vous appliquez correctement l'**autorisation**, l'**identification** et la **protection**, seules les personnes autorisées devraient avoir accès aux données.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

### L'Intégrité

L'intégrité repose sur la prévention de la modification des données en cas de violation. La protection des données par mot de passe est une méthode courante pour accroître l'intégrité. D'autres méthodes consistent à consigner toutes les modifications apportées aux données et à conserver ces journaux afin de pouvoir analyser et atténuer l'ampleur et l'impact de toute violation. Comme pour tout type de sécurité, il est préférable de la mettre en œuvre par paliers afin de maximiser la protection et de minimiser les risques. Une bonne approche systématique pour la sécurité des systèmes informatiques de votre bureau consiste à utiliser une combinaison de politiques et de technologies, notamment la protection des données par mot de passe, avec des autorisations de fichiers limitées (adaptées au département/à l'utilisation/à la disponibilité), un pare-feu de haute sécurité, le cryptage des données et un réseau de routage approprié.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

### La Disponibilité

La disponibilité comprend la disponibilité virtuelle et physique, c'est-à-dire l'accès aux systèmes par voie électronique et la possibilité que les ressources de stockage ou de traitement soient compromises. Bien qu'un verrouillage complet des systèmes puisse constituer une sécurité totale, ils ne seraient pas accessibles. La disponibilité des données est une idée opposée qui doit être équilibrée en conséquence lorsque vous construisez un réseau ou un accès général à l'information. Il faut donc laisser une certaine liberté aux utilisateurs, mais celle-ci doit rester limitée en fonction des besoins. Les responsables doivent appliquer une stratification de l'accès - en créant des structures de classement spécifiques dans un serveur de fichiers ou un site SharePoint qui permet aux utilisateurs d'accéder uniquement aux zones requises par leur rôle - et en limitant ainsi les informations en fonction du « besoin de connaître ». Cette stratégie doit également être appliquée aux fichiers de données stockés sur papier, tels que les dossiers du personnel, les documents contractuels et financiers, les politiques et plans de sécurité, les plans de bureau et les rapports sensibles.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

Les responsables doivent sécuriser les informations en envisageant l'application des mesures suivantes :

- **Une Politique de Bureau Claire** : Une « Politique de Bureau Claire » peut limiter la disponibilité des informations pour les personnes non autorisées. Les informations sensibles peuvent être mises sous clé lorsqu'elles ne sont pas utilisées, en particulier pendant la nuit lorsque les nettoyeurs peuvent avoir un accès illimité à l'installation. Le personnel qui utilise des données sensibles doit disposer d'armoires ou de pièces verrouillables où les données peuvent être sécurisées. La politique de bureau pour ce bureau est la suivante :

| Oui                      | Non                      | Contrôles de la Sécurité de l'Information                                          |
|--------------------------|--------------------------|------------------------------------------------------------------------------------|
| <input type="checkbox"/> | <input type="checkbox"/> | Tous les documents sensibles sont enfermés dans les bureaux à la fin de la journée |
| <input type="checkbox"/> | <input type="checkbox"/> | Une armoire / un conteneur verrouillable est prévu pour sécuriser les informations |
| <input type="checkbox"/> | <input type="checkbox"/> | Une salle dédiée est prévue pour sécuriser les informations                        |

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

- **La Sécurisation des Données** : Les salles de serveurs doivent être sécurisées pour empêcher l'accès et, idéalement, être équipées d'un système d'alarme pour alerter les responsables en cas de violation. Les clés USB et autres dispositifs portables doivent être mis sous clé ou portés sur la personne de l'utilisateur.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

- **Le Voyage avec des Données** : Les voyageurs doivent réfléchir aux informations dont ils ont besoin pour le voyage et se demander si la perte d'une information peut compromettre les individus, le bureau ou l'organisation. Le personnel ne doit pas stocker de données sensibles sur des lecteurs flash ou des disques durs externes, sauf s'il y est autorisé. Les lecteurs flash ou externes d'autres actifs informatiques ne doivent pas, sauf autorisation, être connectés à un ordinateur de travail.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

# Perte et Élimination des Données

Les responsables et le personnel doivent comprendre le processus correct pour éliminer les données ou écarter les risques de vol de données lorsque des équipements ou des documents sont éliminés ou transférés dans un autre bureau. Souvent, les actifs informatiques conservent des données sensibles, même après que le personnel pense avoir assaini l'actif. Les mesures suivantes seront prises lors de l'élimination des données ou lorsque des vols de données se sont produits :

- **Vol de Données** : En cas de perte ou de vol de données ou de biens, le personnel et les responsables doivent immédiatement signaler l'incident et fournir une liste complète des informations volées ou perdues afin qu'une évaluation des risques puisse être effectuée quant aux implications potentielles de la perte. Toutes les parties concernées, y compris les parties prenantes internes et externes touchées, doivent être informées. Il peut également être nécessaire d'informer la police ou les organismes gouvernementaux. Les mêmes considérations s'appliquent si l'on pense que des données ont été compromises. Les vols de données doivent être immédiatement signalés au Siège de l'entreprise.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

- **Effacement des Données** : Le département des Technologies de l'Information est responsable de l'élimination de tous les dispositifs de réseau, disques durs, lecteurs flash et ordinateurs afin de s'assurer que le contenu de ces dispositifs est complètement effacé.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

- **Élimination des Identités** : Les identités ainsi que les ordinateurs peuvent être éliminés s'ils sont compromis. Ces identités jetables permettent d'éviter le harcèlement des traqueurs, en donnant à l'utilisateur la possibilité de choisir qui connaît sa nouvelle identification électronique.

Insérez ici des informations supplémentaires si nécessaire  
Insérez ici des informations supplémentaires si nécessaire

- **Elimination des Données Matérielles :** Les fichiers physiques de données, le papier et les documents doivent être détruits d'une manière qui protège l'intégrité de l'information. Cela peut se faire à l'aide d'une déchiqueteuse, ou en l'absence de déchiqueteuse, les documents peuvent être brûlés. Dans certaines régions, il est possible de faire appel à des entreprises professionnelles pour éliminer les données en toute sécurité. Ces entreprises doivent être contrôlées avant d'être engagées.

Insérez ici des informations supplémentaires si nécessaire

Insérez ici des informations supplémentaires si nécessaire